

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT3)

Assessment Tool Weightage: 30%

Duration: 90 min Total Marks: 50

Report Analysis

Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**

Commands:

- nmap [Target IP Address]
- nmap -sV [Target IP Address]
- nmap -O [Target IP Address]
- nmap -A [Target IP Address]
- nmap -p [Port1,Port2,Port3] [Target IP Address]

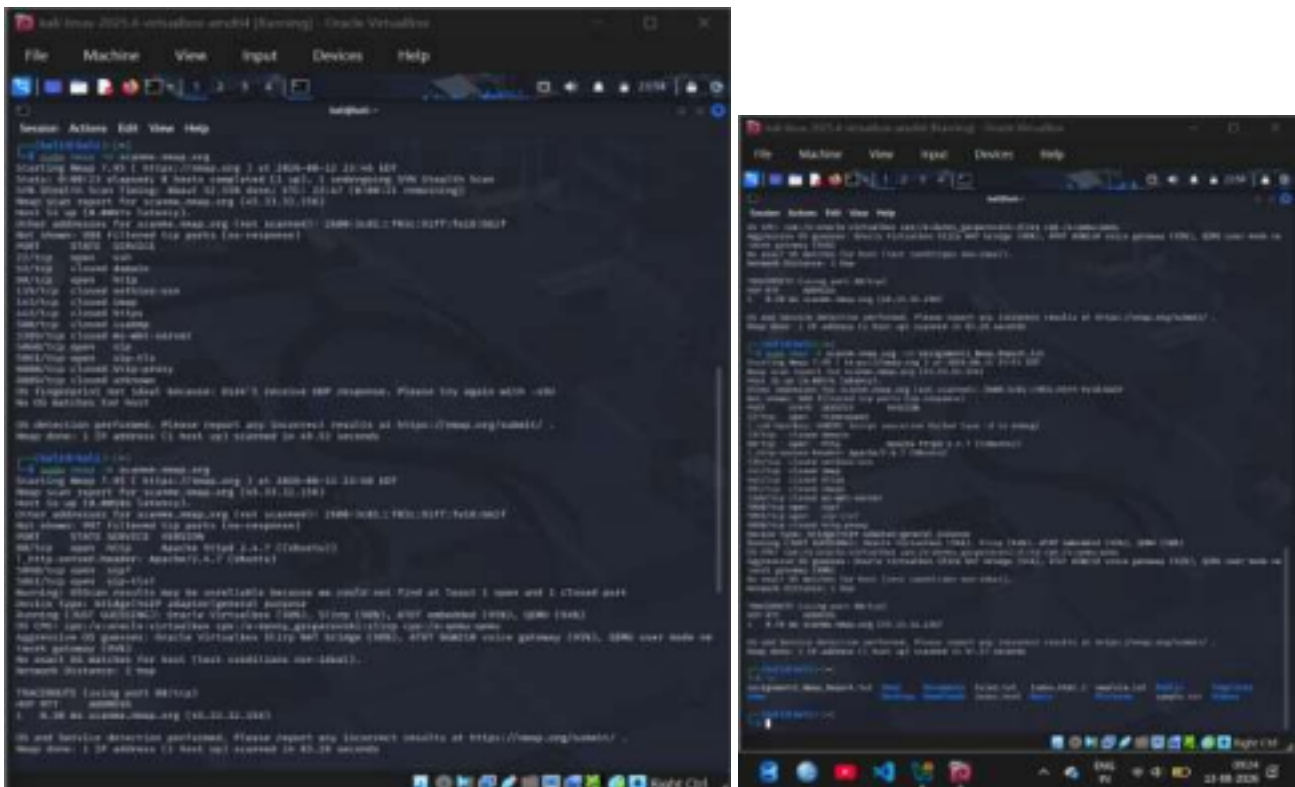
Observations:

- Open Ports: Ports 22, 80, and 3306 were found open.
- Running Services: SSH, HTTP, and MySQL services were detected.
- Service Versions: The versions of the running services were identified.
- OS Detection: The target system's operating system was identified or estimated.
- Security Exposure: The open services may increase the system's attack surface if they are not properly secured.

Security Recommendation:

- ## Reports:





2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(20 Mark).

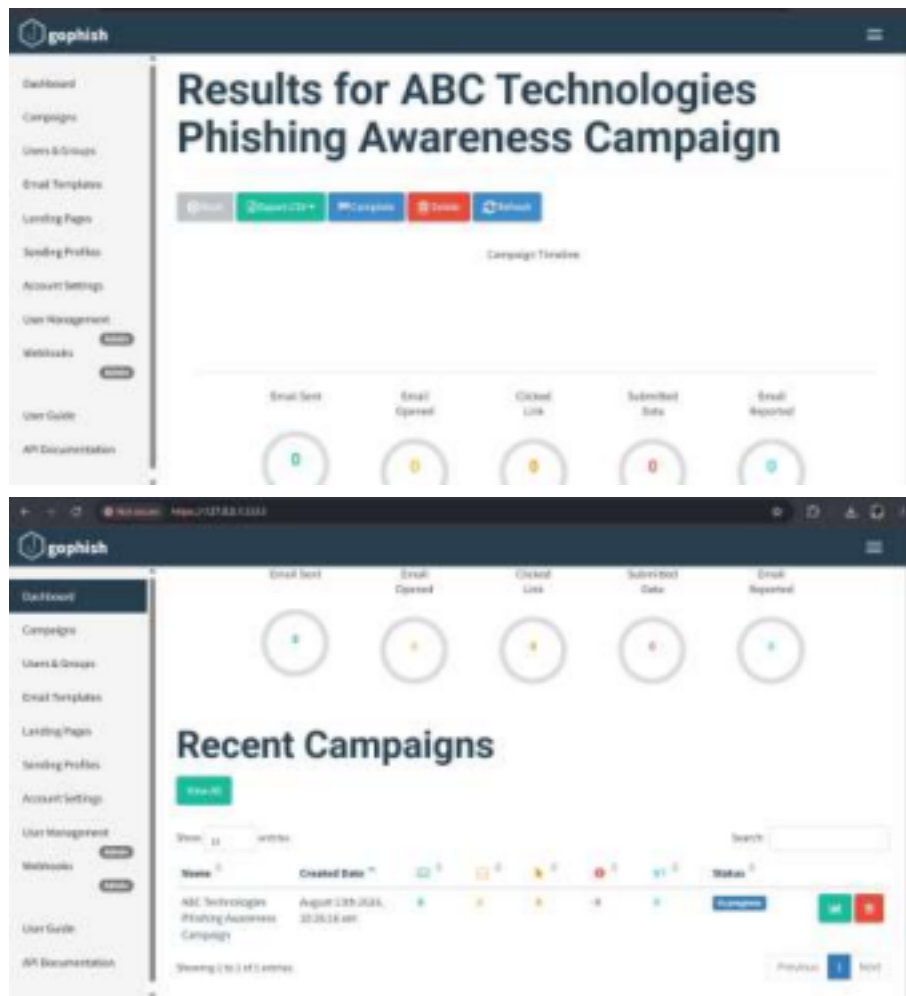
Procedure:

- Plan the campaign – Define the objective and target users.
- Create a simulation – Prepare a safe phishing email using GoPhish.
- Run the campaign – Send the simulated emails to authorized employees.
- Record results – Track clicks, credential submissions, and attachment downloads. •
- Provide training – Educate employees about phishing and social engineering. •
- Repeat testing – Conduct regular simulations to measure improvement.

Email Security Controls:

- Use spam filters to detect phishing emails.
- Enable SPF, DKIM, and DMARC to prevent email spoofing.
- Scan attachments for malware.
- Block risky file types and suspicious attachments.
- Use URL filtering to block malicious links.
- Enable MFA to protect compromised accounts.

- Allow users to report suspicious emails.



3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..(10 Marks)

Commands:

`dig @<DNS-Server-IP> <Domain-Name> AXFR`

Observations:

- AXFR was successful, showing that the DNS server allows zone transfers.
- Internal hostnames and DNS records were exposed.
- Mail server information was revealed through DNS records.
- The records exposed details about the organization's network infrastructure.
- The information can help attackers perform reconnaissance and identify potential targets.

Possible Attacks:

- **Discover hosts** – Identify internal servers and their IP addresses.
- **Map the network** – Understand the organization's DNS and server structure.

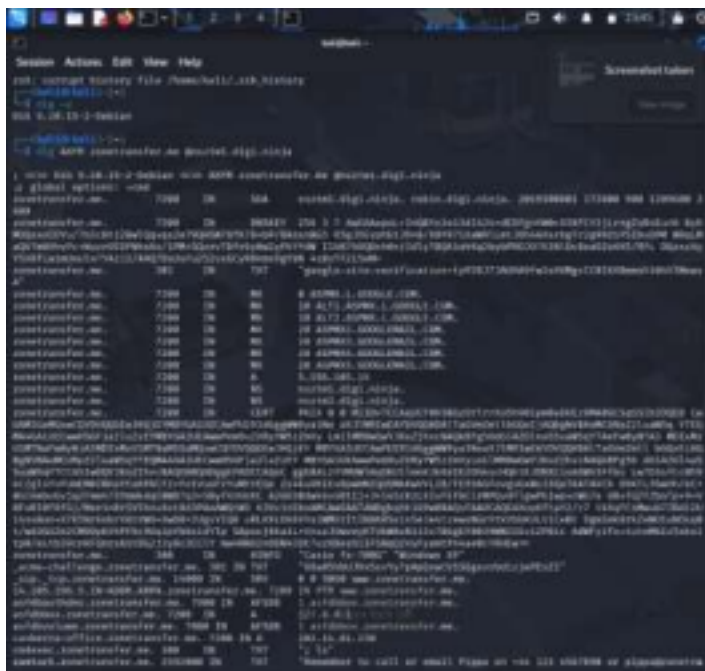
Find targets – Identify important services such as web and mail servers.

- **Identify vulnerabilities** – Target servers that may be outdated or poorly secured.
- **Plan further attacks** – Use the collected information for phishing or unauthorized access attempts.

Security Recommendations:

- **Restrict AXFR** – Allow zone transfers only to authorized DNS servers.
- **Use ACLs** – Permit transfers only from trusted IP addresses.
- **Enable TSIG authentication** – Authenticate DNS zone-transfer requests.
- **Protect internal records** – Keep sensitive DNS information private.
- **Monitor DNS activity** – Regularly check DNS logs for unauthorized transfer attempts.

Report:





Code of Conduct:

I G NITHYA SREE certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.

Identificati on of Security Risks and Vulnerabili tie s	25%	Correctly identifies all security risks, vulnerabiliti es, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabiliti es with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilitie s.
Applicati on of Cybersec urit y Concepts and Countermea sures	30%	Applies appropriate ethical hacking concepts and recommends comprehensi ve, practical, and technically sound countermeasur es.	Recommen ds suitable countermeas ure s with minor technical gaps.	Provides limited or partially appropriate recommenda tio ns.	Recommend ati ons are inappropriat e, incomplete, or missing.
Technical Communic ati on and Document ati on	20%	Response is well organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandab le with minor documentati on or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.